

Sécurité Informatique

Élaboré par Dr. Wafa BERRAYANA

LF3 Info | ING 2 Info

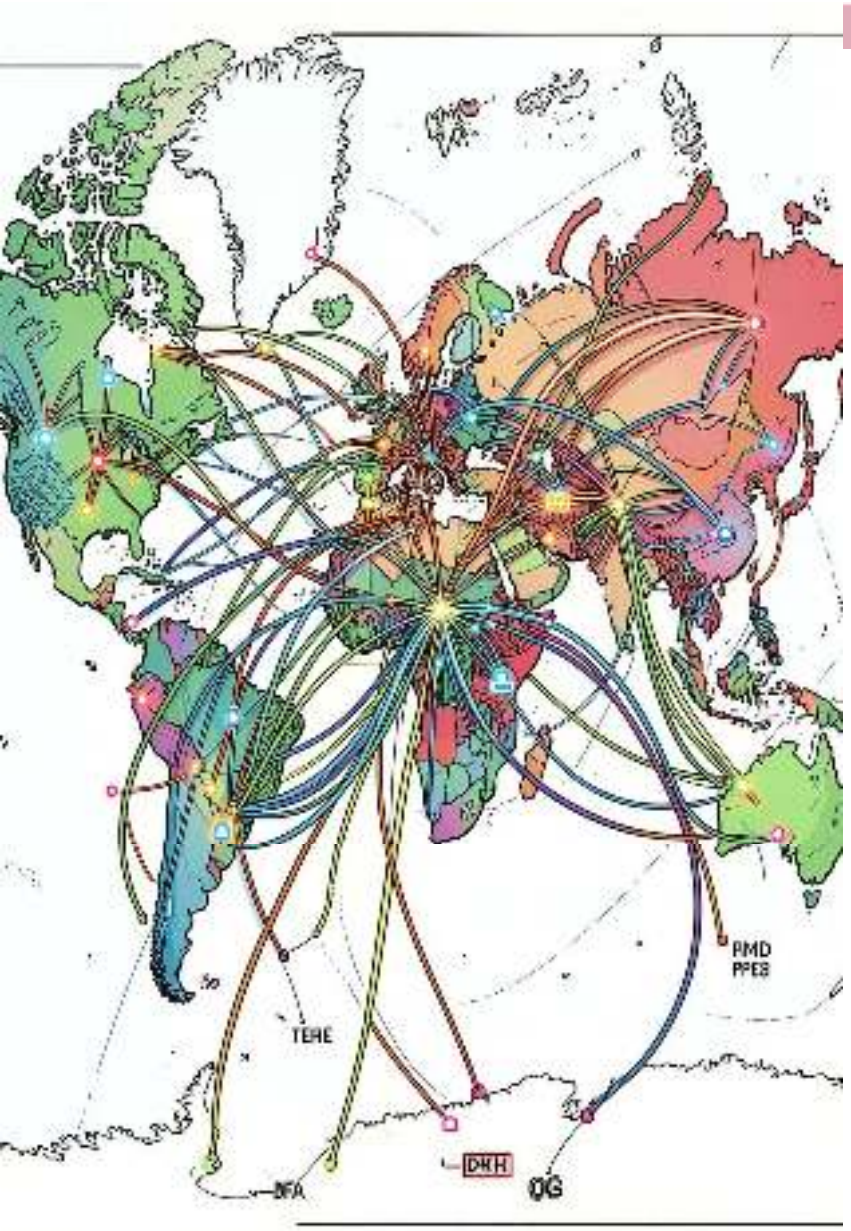
Année Universitaire 2026/2027

wafa.berrayana@gmail.com

Objectifs du cours

L'objectif de ce cours est de fournir aux étudiants :

- ❑ Une introduction aux **concepts de base** de la sécurité informatique.
- ❑ Des connaissances pratiques solides en matière de **cryptographie** : définitions et terminologies, crypto-systèmes classiques, crypto-systèmes symétriques, crypto-systèmes asymétriques, hachage, signature numérique, etc.



INTRODUCTION

Une minute sur Internet

Chaque minute, des milliards d'actions se produisent en ligne : emails envoyés, recherches effectuées, connexions établies.

Cette activité **frénétique** illustre l'ampleur des données circulant sur les réseaux mondiaux — et l'exposition permanente aux menaces cybernétiques.

Une minute Internet — Les chiffres clés



Ces statistiques révèlent l'activité numérique mondiale en temps réel. Chaque minute qui passe génère des données massives — et autant d'opportunités pour les cyberattaquants d'exploiter les vulnérabilités des systèmes.

Plus le trafic est intense, plus la surface d'attaque est grande. La sécurité doit évoluer à la même vitesse que la croissance du numérique.

MOTIVATION

Pourquoi la sécurité informatique est essentielle

- La sécurité informatique protège les **systèmes, réseaux et données** contre les attaques, accès non autorisés et pertes
- Elle prévient le vol d'informations sensibles, les interruptions de service et les atteintes à la réputation.

Confidentialité

Protéger les informations sensibles des accès non autorisés

Continuité

Garantir la disponibilité des services et opérations

Confiance

Préserver la réputation et la relation client



MOTIVATION

Sécurité : Entreprises & Individus

Pour les entreprises

La sécurité garantit la **confidentialité, l'intégrité et la disponibilité** des informations, assurant la continuité des opérations et la confiance des clients. Elle protège contre les ransomwares, virus et autres menaces, et facilite la reprise après incident.

Au niveau individuel

Avec l'usage généralisé des appareils connectés, la sécurité est nécessaire pour protéger les **données personnelles** contre le vol et les abus. Elle contribue aussi à la protection des infrastructures critiques et à la stabilité économique et politique.

Objectifs du chapitre

- **Chapitre 1:** Notions de base sur la sécurité informatique
- **Chapitre 2 :** Les principales attaques sécuritaires
- **Chapitre 3 :** Cryptologie: Introduction & Notions de base
- **Chapitre 4 :** Cryptographie symétrique
- **Chapitre 5 :** Cryptographie asymétrique
- **Chapitre 6 :** Sécurité des Bases de données

CHAPITRE 1

Notions de base sur la sécurité informatique

Comprendre l'évolution de la technologie et des menaces pour mieux appréhender les enjeux actuels de la cybersécurité.



Objectifs du chapitre

- Comprendre les concepts fondamentaux de la sécurité informatique
- Maîtriser le vocabulaire technique (menace, vulnérabilité, attaque, risque)
- Identifier les objectifs de sécurité (CIA + extensions)
- Classifier les types d'attaques et les mécanismes de défense
- Introduire la gestion des risques et la politique de sécurité

CHAPITRE 1 — ÉVOLUTION

Progrès technologique & Sécurité requise (1)

Début XXe siècle – années 1940

1

Technologies : Machines de Turing, Z3 (1941), ENIAC (1946).

Sécurité : Confidentialité par contrôle d'accès physique. Aucune menace électronique.

2

Années 1950–1970

Technologies : Compilateurs (Grace Hopper), UNIX (1969), microprocesseur Intel 4004 (1971).

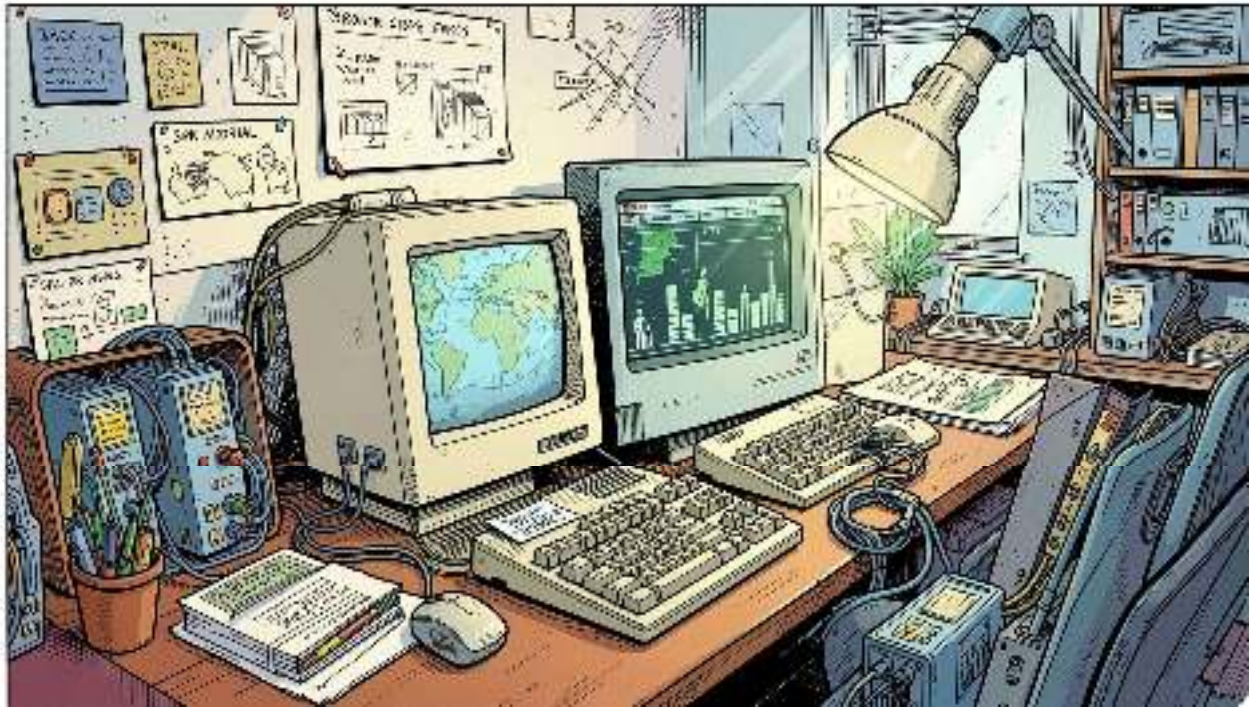
Sécurité : Premiers identifiants, réflexion sur la protection des données.

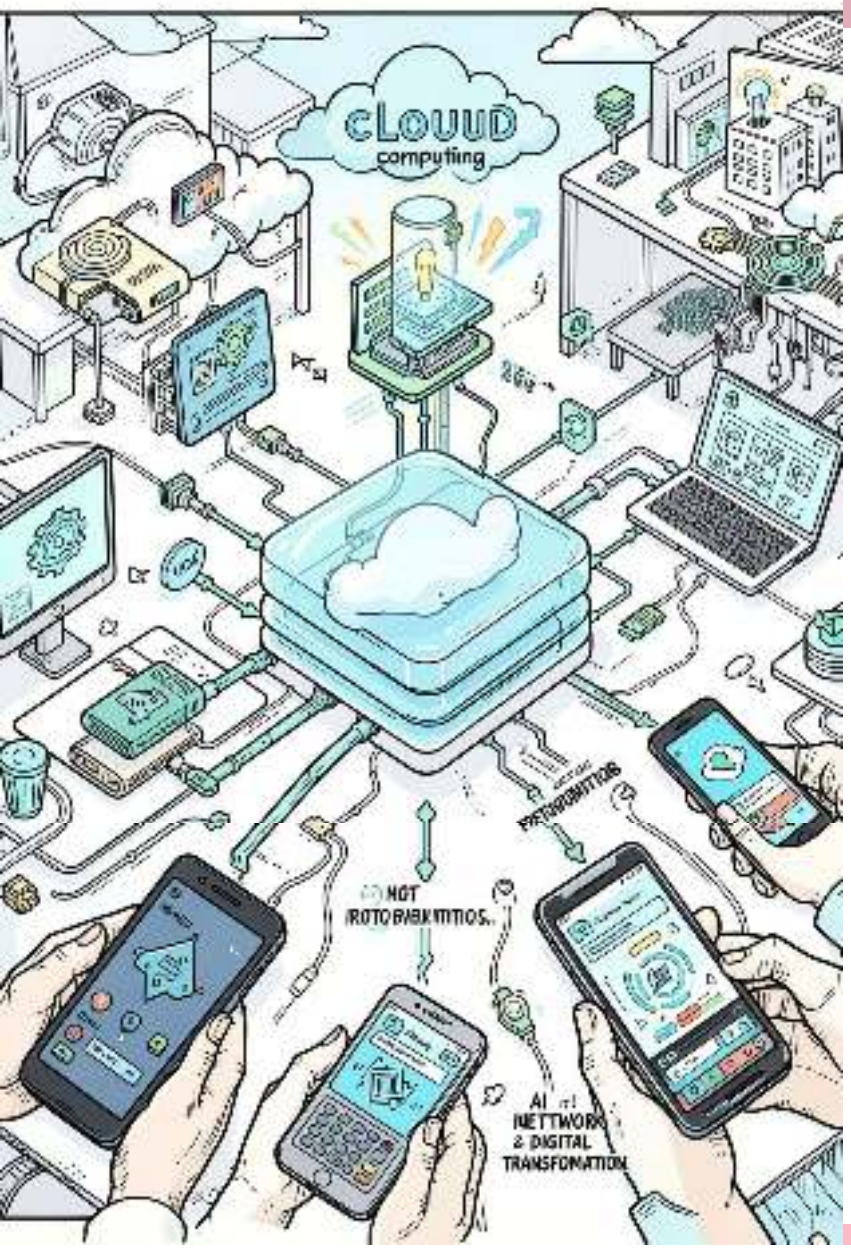
Progrès technologique & Sécurité requise (2)

Années 1980–1990

Technologies : Premiers PC IBM (1981), développement de TCP/IP et ARPANET, invention du Web (1989).

Sécurité : Protection des accès personnels, premiers antivirus, sensibilisation aux virus, rudiments de pare-feu réseau.





CHAPITRE 1 — ÉVOLUTION

Progrès technologique & Sécurité requise (3)

Années 2000 à aujourd'hui : Explosion d'Internet, Cloud, IA, IoT et mobilité.

Risques actuels

Ransomwares, phishing, DDoS, vol massif de données, failles cloud et mobiles.

Sécurité requise

Politiques cybersécurité avancées, cryptographie, IAM, RGPD, monitoring continu et gestion des vulnérabilités.

« *La sécurité informatique consiste à garantir que les ressources matérielles ou logicielles d'une organisation sont uniquement utilisées dans le cadre prévu* » JF Pillou

But

Préserver la confidentialité, la disponibilité et l'intégrité des ressources d'un système

Comment?

- Analyse de vulnérabilités et d'attaques
- Mise en œuvre de moyens humains, organisationnels et techniques en prévention de la menace

Pourquoi

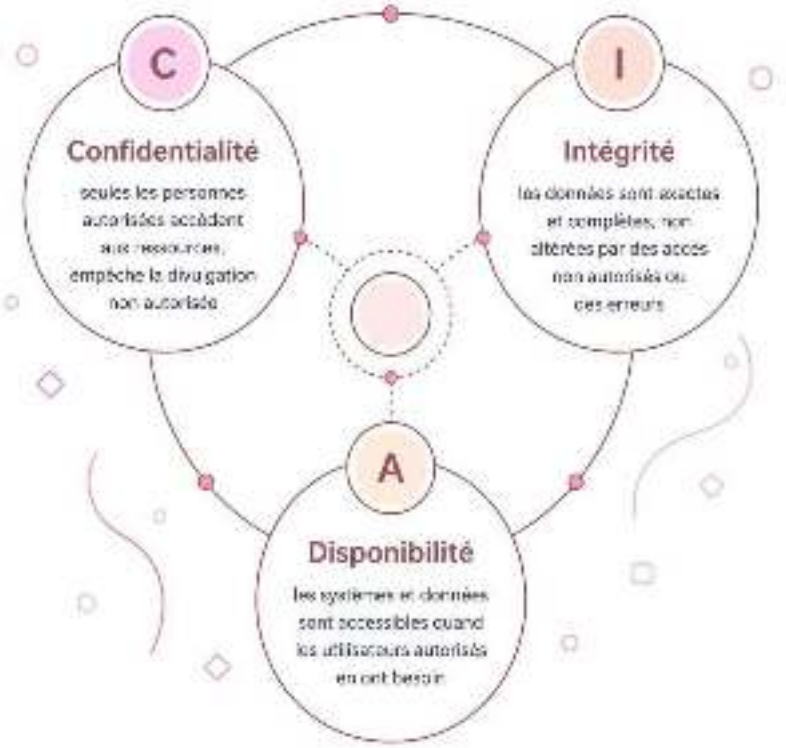
- La valeur des biens, des données et des services informatisés
- Si ces données et services sont perdus, volés ou altérés, quelles seront les conséquences ?

Concepts Fondamentaux

Le Modèle CIA (Triade de Base)

La sécurité informatique repose sur trois piliers essentiels, résumés par le sigle CIA

CIA: : Confidentiality - Integrity - Availability..



Confidentialité

Seules les personnes autorisées accèdent aux ressources. Empêche toute divulgation non autorisée.

Intégrité

Les données sont exactes, complètes et non altérées par des accès non autorisés ou des erreurs.

Disponibilité

Les systèmes et données sont accessibles et fonctionnels lorsque les utilisateurs en ont besoin.

Formule clé : Sécurité = Confidentialité + Intégrité + Disponibilité

Extensions du Modèle CIA

Authentification

Vérification de l'identité des utilisateurs ou des systèmes
Exemple : mot de passe, certificat, biométrie, MFA.

Autorisation / contrôle d'accès

Déterminer ce qu'un utilisateur authentifié a le droit de faire.
Exemple : un étudiant peut consulter ses notes mais ne peut pas les modifier

Traçabilité / audit

Conserver les traces des actions effectuées dans le système.
Exemple : journaux de connexion, logs, SIEM.

Non-répudiation

Impossibilité pour une partie de nier avoir effectué une action
Exemple : signature électronique et certificats numériques.

Concepts Clés - Menace

- **Définition :** Cause potentielle d'un incident de sécurité
- **Origines :**
  - Humaine (pirate, utilisateur malveillant)
  - Logicielle (virus, malware)
  - Matérielle (panne, catastrophe naturelle)
- **Exemples :**
  - Phishing, ransomware, déni de service, erreur humain

Concepts Clés - Attaque

- **Définition :** Exploitation volontaire d'une vulnérabilité par une menace dans le but de compromettre un système ou des données
- **Objectifs :**
  - Compromettre la confidentialité (accès non autorisé)Compromettre l'intégrité (modification, suppression)
  - Compromettre la disponibilité (interruption de service)
- **Exemple :** Attaque par force brute exploitant un mot de passe faible

Relations entre Concepts

❑ Schéma :

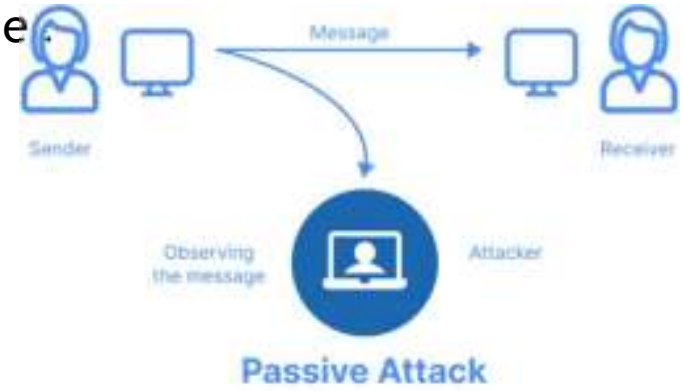


❑ Ressources à protéger :

- ❑ Bases de données clients
- ❑ Codes sources
- ❑ Portails web
- ❑ Réputation de l'entreprise

Attaques informatique (1)

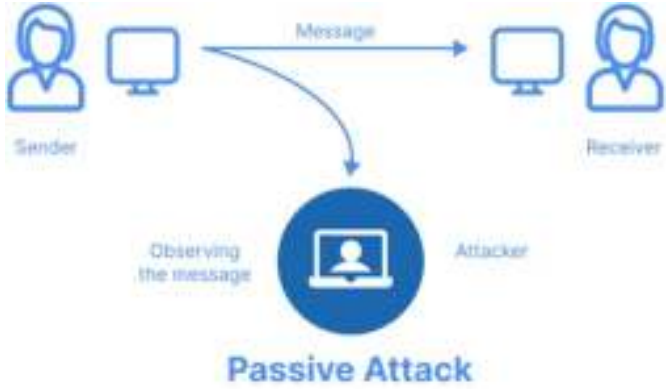
- L'attaque informatique peut viser un système, un réseau ou un appareil informatique pour en compromettre la **confidentialité** et/ou **l'intégrité** et/ou **la disponibilité**
- On distingue deux grands types d'attaques selon la manière dont l'attaquant **agit** sur le système :





- Ces deux types d'attaques sont complémentaires et **souvent** combinés dans des attaques complexes : d'abord une attaque passive pour recueillir des informations, puis une attaque active pour exploiter les vulnérabilités découvertes.

Attaques informatique (2)



- **Attaque passive**
  - **Caractéristiques**
    - Observation ou interception sans modifier le système
    - Difficiles à détecter (pas de traces visibles)
    - Objectif principal : compromettre la confidentialité
  - **Exemples**
    - Écoute du trafic réseau (sniffing)
    - Analyse de flux réseau
    - Interception de communications non chiffrées
  - **Impact prioritaire :** menace sur la confidentialité.

Attaques informatique (3)



❑ Attaques Passives – Sniffing

- ❑ Principe : Capturer les données qui circulent sur un réseau.
- ❑ Outils : Wireshark, tcpdump
- ❑ Exemple concret : Récupération de mots de passe sur un Wi-Fi public non sécurisé.
- ❑ Contre-mesure : Chiffrement des communications (HTTPS, VPN, TLS).

❑ Attaques Passives – Analyse de Flux

- ❑ Principe : Étudier les caractéristiques du trafic (volume, durée, fréquence) sans lire le contenu
- ❑ Objectif : Déduire des informations sur le fonctionnement du système.
- ❑ Exemple : Identifier qu'un serveur reçoit beaucoup de trafic le vendredi soir → planifier une attaque DoS.
- ❑ Contre-mesure : Techniques de masquage de trafic (padding, trafic factice)

Attaques informatique (4)



❑ Attaque active

- ❑ L'attaquant intervient directement en modifiant, perturbant ou détruisant les ressources, les données ou fonctions du système.
- ❑ **Objectif :** sabotage, déni de service, injection de code malveillant.
- ❑ **Exemple :** ransomware (chiffrement des données), attaques par déni de service (DoS), modification de bases de données.
- ❑ **Caractéristique :** souvent détectable car cause un impact visible ou interruption.
- ❑ **Impact prioritaire :** menace sur la disponibilité et l'intégrité.

Attaques informatique (5)



❑ Attaques Actives – Déni de Service (DoS/DDoS)

- ❑ **Principe :** Rendre un système indisponible en le surchargeant.
- ❑ **Méthodes :**
  - ❑ Envoi d'un volume de trafic très important
  - ❑ Envoi de paquets malformés (ex. SYN flood, Ping of Death)DDoS : Attaque distribuée depuis plusieurs machines (botnet)
- ❑ **Contre-mesure :** Pare-feu, limitation de débit, CDN, services anti-DDoS

❑ Attaques Actives – Modification de Données

- ❑ **Principe :** Altérer les données lors de leur transmission ou stockage.
- ❑ **Exemples :**
  - ❑ Modification d'un message entre deux utilisateurs
  - ❑ Altération d'une base de données (ex. notes, soldes bancaires)
- ❑ **Service affecté :** Intégrité
- ❑ **Contre-mesure :** Fonctions de hachage, signatures numériques.

Attaques informatique (6)

❑ Attaques par Ingénierie Sociale

- ❑ **Phishing (Hameçonnage) :** Tromper les utilisateurs via des emails semblant provenir d'une institution de confiance
- ❑ **Objectif :** Récupérer des informations confidentielles (identifiants, cartes bancaires).
- ❑ **Exemple :** Email imitant une banque demandant de cliquer sur un lien.
- ❑ **Contre-mesure :** Formation des utilisateurs, filtres anti-phishing, vérification des URLs

❑ Attaques Techniques – Injection SQL

- ❑ **Principe :** Envoyer des données non fiables à un interpréteur SQL pour exécuter des requêtes non autorisées.
- ❑ **Impact :** Accès à des données sensibles, modification/suppression de données.
- ❑ **Exemple :** ' OR '1'='1 dans un formulaire de connexion
- ❑ **Contre-mesure :** Requêtes paramétrées, validation des entrées, moindre privilège.

Attaques informatique (7)

- **Programmes Malveillants (Malware)**
  - Virus : Logiciel attaché à un document, nécessite une intervention humaine
  - Ver (Worm) : Se reproduit automatiquement via le réseau
  - Cheval de Troie : Programme bénin cachant un malware (backdoor)
  - Ransomware : Chiffre les fichiers et demande une rançon
  - Spyware/Keylogger : Collecte des informations (frappes clavier, navigation)

Les Hackers



Qui sont les Hackers ? – Définitions

- **Hacker (origine) :** Terme neutre désignant un expert en informatique capable de comprendre et modifier des systèmes

- **Évolution du terme :** Aujourd'hui souvent associé aux activités malveillantes, mais tous les hackers ne sont pas criminels

- **Différence clé :**
  - Hacker éthique (White Hat) : Travaille légalement pour sécuriser les systèmes
  - Cracker (Black Hat) : Utilise ses compétences à des fins malveillantes

Classification des Hackers par Chapeau

- **White Hat (Chapeau Blanc) :**
  - Hackers éthiques, travaillent pour des entreprises ou en tant que consultants
  - Objectif : Identifier et corriger les vulnérabilités
  - Exemple : Pentesters, chercheurs en sécurité

- **Gray Hat (Chapeau Gris) :**
  - Agissent sans autorisation mais sans intention malveillante
  - Exemple : Découvrent une faille et la révèlent publiquement

- **Black Hat (Chapeau Noir) :**
  - Hackers malveillants, motivés par le profit, l'espionnage ou le sabotage
  - Exemple : Cybercriminels, ransomware gangs

Autres Catégories de Hackers

- **Script Kiddies :** Utilisent des outils préfabriqués sans comprendre leur fonctionnement
- **Hacktivistes :** Motivés par des causes politiques ou idéologiques (ex. Anonymous)
- **Cyber-espions :** Employés par des États ou organisations pour voler des secrets
- **Insiders (Menace interne) :** Employés ou anciens employés ayant un accès légitime

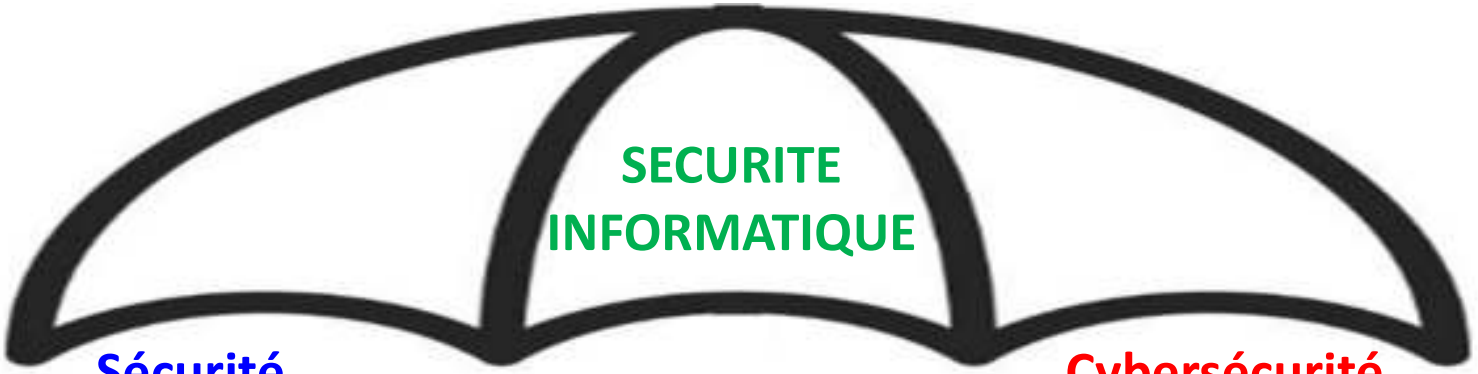
- **Motivations des Hackers**
  - **Financières :** Vol de données bancaires, ransomware, fraude
  - **Politiques/Ideologiques :** Hacktivisme, cyber-guerre
  - **Personnelles :** Défi technique, reconnaissance, vengeance
  - **Espionnage :** Vol de secrets industriels ou gouvernementaux.

Autres Catégories de Hackers

- **Cybercriminels organisés :** groupes structurés, souvent motivés par le profit, menant des campagnes de phishing, d'extorsion ou des attaques par ransomware

- **États-nations (cyberespions) :** organisations gouvernementales qui ciblent des infrastructures critiques ou des bases de données sensibles pour l'espionnage ou la déstabilisation.

Les volets de la sécurité informatique
Que protège-t- on ?



Sécurité informatique: « protection des SI »

- Physique
- Réseau
- Système

Cybersécurité « protection dans le cyberespace »

- Réseaux
- Systèmes
- Données

Sécurité informatique

- **Sécurité informatique** est le terme général qui concerne la protection des :
  - systèmes informatiques
  - ordinateurs et serveurs
  - Réseaux
  - applications
  - bases de données
  - données
  - équipements physiques
  - utilisateurs.

- **Cybersécurité** se concentre davantage sur la protection contre les menaces et attaques dans l'environnement numérique/cyberespace. Elle comprend notamment :
  - attaques réseau
  - malware et ransomware
  - phishing
  - attaques Web vol d'identifiants
  - DDoS
  - espionnage et exfiltration de données
  - attaques contre le Cloud
  - attaques contre les objets connectés
  - réponse aux incidents
  - détection des intrusions.

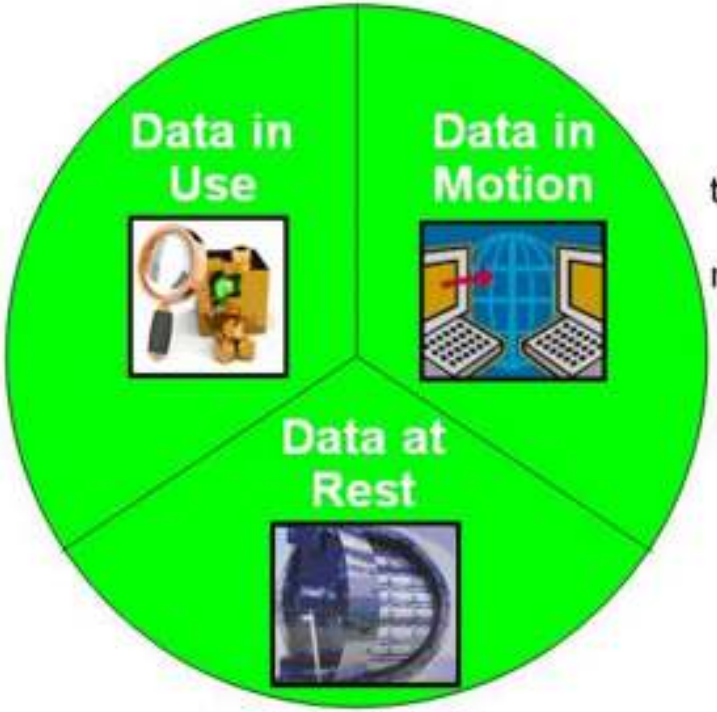
Type de sécurité	Ce qu'elle protège	Exemples
Sécurité réseau	Réseaux et communications	Pare-feu, IDS/IPS, VPN, segmentation
Sécurité des systèmes	Ordinateurs, serveurs et OS	Antivirus, mises à jour, durcissement
Sécurité des données	Informations stockées ou transmises	Chiffrement, sauvegarde, contrôle d'accès
Sécurité des applications	Logiciels et applications Web	Anti-SQL Injection, XSS, authentification
Sécurité des bases de données	Bases de données et SGBD	Droits d'accès, chiffrement, audit
Sécurité du Cloud	Services et données dans le Cloud	IAM, chiffrement, isolation
Sécurité IoT	Objets et équipements connectés	Authentification, mises à jour, chiffrement
Sécurité mobile	Smartphones et tablettes	Code PIN, MDM (Mobile Device Management), chiffrement
Sécurité physique	Locaux et équipements informatiques	Contrôle d'accès, vidéosurveillance
Sécurité des utilisateurs	Utilisateurs et comportements	Sensibilisation, phishing, mots de passe
Sécurité des communications	Échanges de données	TLS/HTTPS, IPsec, VPN
Cybersécurité	protège l'ensemble des systèmes informatiques, des réseaux, des appareils connectés et des données contre les attaques numériques, les vols et les dommages	

Ressources et violation de la sécurité

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service.		
Software	Programs are deleted, denying access to users.	An unauthorized copy of software is made.	A working program is modified, either to cause it to fail during execution or to cause it to do some unintended task.
Data	Files are deleted, denying access to users.	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data.	Existing files are modified or new files are fabricated.
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable.	Messages are read. The traffic pattern of messages is observed.	Messages are modified, delayed, reordered, or duplicated. False messages are fabricated.

Les états de la donnée

Data in Use:
Active data under constant change stored physically in databases, data warehouses, spreadsheets etc.



Data in Motion:
Data that is traversing a network or temporarily residing in computer memory to be read or updated.

Data at Rest:
Inactive data stored physically in databases, data warehouses, spreadsheets, archives, tapes, off-site backups etc.

Implémentation de la sécurité

Objectifs de sécurité

❑ L'implémentation de la sécurité

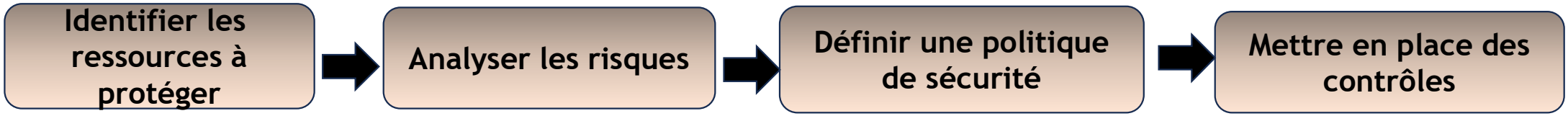
- ❑ consiste à appliquer concrètement des mesures techniques, organisationnelles et humaines afin de protéger les systèmes d'information, les réseaux, les applications et les données

❑ Objectifs de sécurité

- ❑ Elle repose généralement sur les trois principes fondamentaux de la triade CIA :

Principe	Objectif	Exemple
Confidentialité	Empêcher l'accès aux personnes non autorisées	Chiffrement des données
Intégrité	Garantir que les données ne sont pas modifiées illicitement	Hachage, signatures numériques
Disponibilité	Maintenir l'accès aux services autorisés	Sauvegardes, redondance, plan de reprise

Étapes d’implémentation



- **Identifier les ressources : Il faut d’abord recenser les ressources à protéger :**
  - Serveurs et postes de travail
  - Bases de données
  - Applications web
  - Équipements réseau
  - Comptes utilisateurs
  - Données personnelles ou confidentielles
  - Services cloud et sauvegardes

Étapes d'implémentation

- **Analyser les risques :** Pour chaque ressource, on identifie :
  - Les menaces possibles
  - Les vulnérabilités existantes
  - La probabilité d'une attaque
  - L'impact potentiel.
  - Le niveau de risque

- **Une formule simple est :**

$$Risque = Probabilité \times Impact$$

- **Exemple :** une base de données contenant des informations clients et accessible directement depuis Internet présente un risque élevé.

Étapes d'implémentation

- **Définir une politique de sécurité :** La politique doit préciser :
  - Les règles de création des mots de passe
  - La gestion des comptes et des privilèges
  - L'utilisation acceptable des équipements
  - Les procédures de sauvegarde
  - La réponse aux incidents
  - La gestion des mises à jour
  - Les règles de chiffrement
  - Les obligations de sensibilisation des utilisateurs

- **Mettre en place des contrôles :** Les contrôles peuvent être :
  - **Préventifs :** empêcher une attaque
  - **Détectifs :** identifier une activité suspecte
  - **Correctifs :** rétablir la situation après un incident.

Implémentation de la sécurité (1)

- Mesures techniques essentielles
  - Contrôle des accès
    - Il faut appliquer le principe du **moindre privilège** : chaque utilisateur reçoit uniquement les droits nécessaires à son travail
    - **Exemples :**
      - Utilisation de rôles.
      - Authentification multi-facteur.
      - Désactivation des comptes inactifs.
      - Séparation des comptes administrateur et utilisateur.
      - Révision régulière des permissions
    - Pour une base de données, on peut créer des rôles distincts :

```
CREATE ROLE lecteur;
GRANT SELECT ON clients TO lecteur;
CREATE ROLE administrateur;
GRANT SELECT, INSERT, UPDATE, DELETE
ON clients TO administrateur;
```

Implémentation de la sécurité (2)

- **Mesures techniques essentielles**
  - **Sécurité réseau :** Les principales mesures sont :
    - Pare-feu
    - Segmentation en VLAN
    - Listes de contrôle d'accès, ou ACL
    - VPN pour les connexions distantes.
    - IDS/IPS
    - Désactivation des services inutiles
    - Sécurisation de l'administration avec SSH plutôt que Telnet.



Implémentation de la sécurité (3)



- **Mesures techniques essentielles**
  - **Protection des données:** Les données peuvent être protégées par :
    - Chiffrement pendant le transport avec TLS
    - Chiffrement au repos
    - Hachage des mots de passe avec un algorithme adapté
    - Masquage des données sensibles
    - Sauvegardes chiffrées
    - Gestion sécurisée des clés cryptographiques



  - NOTE: Un mot de passe ne doit pas être stocké en clair



Implémentation de la sécurité (4)

- **Mesures techniques essentielles**
  - **Sécurité des applications :** Pour éviter les vulnérabilités courantes :
    - Utiliser des requêtes préparées contre l'injection SQL
    - Vérifier et filtrer les entrées utilisateur
    - Encoder les sorties HTML contre les attaques XSS
    - Utiliser des jetons CSRF (est un code unique, aléatoire et secret généré par le serveur pour protéger les applications web contre les attaques)
    - Configurer correctement les sessions
    - Ne jamais afficher les messages d'erreur détaillés en production
    - Mettre à jour les dépendances.



Implémentation de la sécurité (5)

- **Mesures techniques essentielles**
  - **Sécurité des applications :** Une procédure de réponse peut suivre ces étapes :
    - Détection de l'incident
    - Analyse et qualification
    - Comprendre la menace
    - Éradication de la cause
    - Restauration des services
    - Retour d'expérience et amélioration



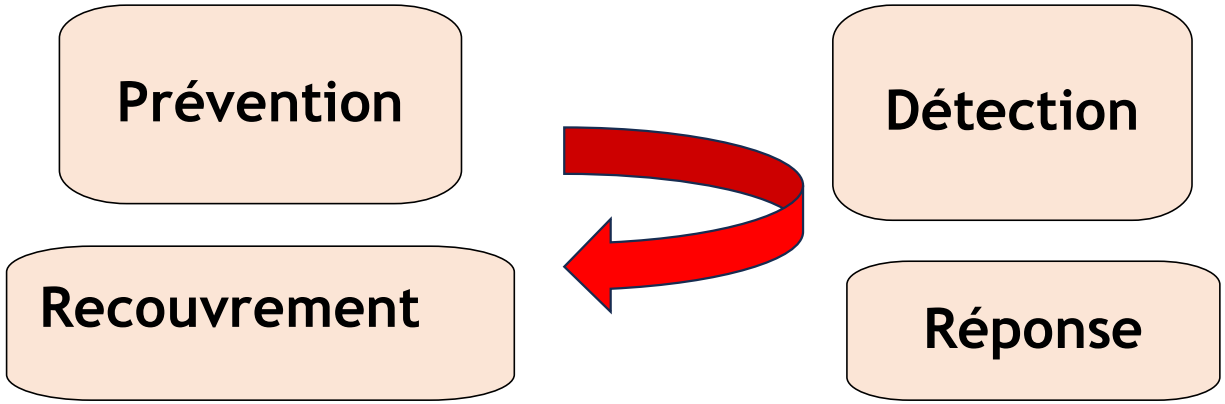
Implémentation de la sécurité (6)

- **Mesures techniques essentielles**
  - **Vérification de l'efficacité:** L'implémentation doit être contrôlée régulièrement à l'aide de :
    - Scans de vulnérabilités
    - Audits de configuration
    - Tests d'accès avec différents rôles
    - Tests de restauration des sauvegardes
    - Analyse des journaux
    - Simulations de phishing
    - Tests d'intrusion avec autorisation
    - Mise à jour de la documentation
  - L'objectif est de vérifier que la sécurité fonctionne réellement et ne se limite pas à une simple configuration initiale

Gestion des menaces et incidents de la sécurité informatique

Gestion des menaces et incidents de la sécurité Informatique (1)

- L'implémentation de la sécurité informatique s'articule autour de quatre phases clés : prévention, détection, réponse et récupération. Ces phases permettent de couvrir le cycle complet de gestion des menaces et incidents de la sécurité informatique



Gestion des menaces et incidents de la sécurité Informatique (2)

- **Prévention**
  - La prévention vise à réduire les vulnérabilités en mettant en place des mesures de protection telles que les pares-feux, le chiffrement, les mises à jour régulières, les contrôles d'accès stricts, ainsi que la sensibilisation et la formation des utilisateurs. L'objectif est de minimiser la surface d'attaque et d'éviter que les incidents ne surviennent

- **Détection**
  - La détection consiste à identifier rapidement les incidents de sécurité grâce à des outils de surveillance continue comme les systèmes de détection d'intrusions (IDS), les journaux d'événements, les solutions SIEM (Security Information and Event Management) ou les services de détection et réponse gérées (MDR). Cette phase est cruciale pour reconnaître et analyser une violation avant qu'elle ne se propage

Gestion des menaces et incidents de la sécurité Informatique (3)

- **Réponse**
  - Une fois un incident détecté, la réponse vise à contenir et neutraliser la menace. Cela inclut l'isolement des systèmes affectés, la suppression des codes malveillants, la correction des vulnérabilités exploitées. La réponse doit être rapide et coordonnée pour limiter l'impact opérationnel et financier, en suivant un plan de réponse aux incidents bien défini

- **Récupération**
  - Enfin, la récupération se concentre sur la restauration des systèmes et des services affectés pour reprendre normalement les activités. Elle implique souvent la restauration des données à partir de sauvegardes et la vérification de l'intégrité post-incidents. Des tests réguliers du plan de reprise après sinistre (DRP) garantissent une capacité efficace de récupération

Récapitulation

Phase	Objectif principal	Moyens typiques
Prévention	Éviter les incidents	Pare-feux, chiffrement, mises à jour, formations
Détection	Identifier rapidement les incidents	IDS, SIEM, journaux, surveillance continue
Réponse	Confinement et neutralisation de la menace	Isolation, suppression d'attaques, plan de réponse
Récupération	Restaurer les systèmes et activités normales	Sauvegardes, tests DRP, contrôle d'intégrité